UNIVERSIDAD DE LAS FUERZAS ARMADAS – ESPE
Departamento de Ciencias de la Computación

Desarrollo de Software Seguro

Resumen descriptivo de la Unidad 1
Introducción y estudio de vulnerabilidades

---

1. Datos informativos

Institución	Universidad de las Fuerzas Armadas – ESPE
Departamento	Ciencias de la Computación
Asignatura	Desarrollo de Software Seguro
Unidad	Unidad 1: Introducción y estudio de vulnerabilidades
Actividad	Elaboración de un resumen descriptivo y documentado
Modalidad	Individual
Tipo de trabajo	Revisión y síntesis documental de los contenidos desarrollados en clase
Valor	20 puntos
Formato de entrega	Documento PDF
Fecha límite	La establecida en el aula virtual (Moodle)

2. Descripción del problema y objetivos

2.1. Descripción del problema

En el desarrollo de aplicaciones modernas, las vulnerabilidades pueden originarse en diferentes niveles: infraestructura física, código fuente, ejecución de scripts, decisiones de diseño y arquitectura. Estudiar cada amenaza de forma aislada dificulta comprender sus consecuencias y la relación existente entre los activos, los riesgos y las medidas de protección. La gestión de riesgos y las prácticas de desarrollo seguro deben considerarse desde las primeras fases del ciclo de vida del software, no exclusivamente al finalizar la implementación [1, 2].

Por ello, se solicita elaborar un **resumen descriptivo, crítico y organizado** de los temas de la Unidad 1, que integre conceptos, clasificaciones y ejemplos breves, relacionando las amenazas estudiadas con la seguridad y resiliencia de una aplicación web. Como referentes de apoyo pueden emplearse las publicaciones de OWASP y MITRE sobre riesgos y debilidades de software [3, 4].

2.2. Objetivo general

Sintetizar de manera clara, coherente y fundamentada los conceptos esenciales de seguridad del software, las amenazas presentes en distintos niveles tecnológicos y las acciones estratégicas para fortalecer la seguridad y resiliencia durante el ciclo de vida del desarrollo.

2.3. Objetivos específicos

1. Explicar los fundamentos de seguridad del software, su importancia, las propiedades de los sistemas seguros y los costos asociados con la explotación de vulnerabilidades.

2. Caracterizar las amenazas a nivel de hardware, código, scripts incrustados, diseño y arquitectura, mediante ejemplos contextualizados.
3. Relacionar los conceptos de activos, amenazas, vulnerabilidades, impacto y tratamiento del riesgo con situaciones propias de aplicaciones web y bases de datos.
4. Describir la incorporación de medidas de seguridad y resiliencia en las fases del SDLC, incluidas las directrices adicionales y los puntos de ataque relevantes.
5. Fundamentar el contenido con fuentes académicas y técnicas verificables, mediante citas y referencias consistentes en APA (7.ª edición) o IEEE.

3. Indicaciones

3.1. Lineamientos de elaboración

1. Elaborar un **resumen descriptivo original**, a partir de los temas revisados en clase y la consulta de bibliografía confiable. No se solicita desarrollar una aplicación, ejecutar ataques ni elaborar una investigación experimental.
2. Mantener el orden temático indicado a continuación. **Todos los 15 subtemas son obligatorios**; los tres apartados principales (1.1, 1.2 y 1.3) deberán introducir brevemente cada bloque.
3. Para cada subtema, presentar una explicación con palabras propias, conceptos esenciales y, cuando corresponda, un ejemplo relacionado con un sistema informático o una aplicación web. Evitar definiciones copiadas y párrafos compuestos únicamente por listados.
4. Mostrar relaciones entre los conceptos: amenazas, vulnerabilidades, consecuencias, medidas preventivas y decisiones en el SDLC. Utilizar subtítulos, cuadros o figuras únicamente cuando aporten claridad.
5. Incluir **al menos seis fuentes** pertinentes, de las cuales por lo menos tres sean documentos técnicos de organismos reconocidos (p. ej., NIST, OWASP o MITRE) y dos sean artículos académicos o libros especializados. Toda afirmación técnica tomada de una fuente debe tener su respectiva cita.
6. Utilizar **APA (7.ª edición) o IEEE**, sin mezclar estilos. La presente guía utiliza IEEE como ejemplo. Incorporar referencias completas y enlaces o DOI cuando estén disponibles.

3.2. Contenido mínimo del resumen

1.1 Introducción

Explicar los conceptos y fundamentos de la seguridad del software mediante los siguientes subtemas:

1.1.1 Qué es la seguridad del software
Definición, propósito y diferencia entre desarrollar funcionalidades y garantizar su comportamiento seguro.

1.1.2 La importancia de la seguridad en el software
Impacto en la protección de usuarios, información, continuidad operativa y confianza.

1.1.3 Las vulnerabilidades y sus costes
Definición de vulnerabilidad; costos técnicos, económicos, legales, reputacionales y de recuperación, sin inventar cifras.

1.1.4 Gestión de riesgos de seguridad del software

Relación entre activo, amenaza, vulnerabilidad, probabilidad, impacto, nivel de riesgo y tratamiento.

1.1.5 Propiedades del software seguro y resiliente

Confidencialidad, integridad, disponibilidad, autenticidad, trazabilidad y capacidad de recuperación, según corresponda.

1.1.6 Conceptos de seguridad

Distinción entre autenticación y autorización; ataque, superficie de ataque, control, incidente y exposición.

1.1.7 Servidores web HTTP, bases de datos

Función de servidores HTTP y sistemas gestores de bases de datos; riesgos de exposición y controles básicos.

1.2 Amenazas a la seguridad del software

Describir cómo se originan amenazas en diferentes capas de un sistema, distinguiendo ejemplos, consecuencias y controles:

1.2.1 Amenazas a nivel de hardware

Acceso físico no autorizado, manipulación de dispositivos, fallas y efectos sobre la disponibilidad.

1.2.2 Amenazas a nivel de código

Fallos de validación, inyección, gestión insegura de errores, secretos expuestos o dependencias vulnerables.

1.2.3 Lenguajes de script incrustados

Riesgos de ejecución de scripts no confiables, especialmente XSS, y medidas de codificación y validación.

1.2.4 Amenazas a nivel de diseño

Falta de controles de acceso, flujos inseguros, ausencia de límites de confianza y errores en requisitos de seguridad.

1.2.5 Amenazas a nivel de arquitectura

Exposición innecesaria de servicios, comunicación insegura, dependencia de puntos únicos de fallo y segmentación deficiente.

1.3 Plan estratégico

Explicar cómo incorporar medidas preventivas, de detección y de respuesta dentro de la planificación del desarrollo:

1.3.1 Seguridad y resiliencia en el SDLC

Prácticas durante requisitos, diseño, implementación, pruebas, despliegue y mantenimiento; relación con *Shift Left* y *Secure by Design* [1, 5].

1.3.2 Directrices de seguridad adicionales

Uso de mínimo privilegio, defensa en profundidad, configuración segura, gestión de parches, monitoreo y copias de respaldo, con su justificación.

1.3.3 Puntos de ataque y seguridad perimetral

Identificación de superficies y puntos de entrada (endpoints HTTP, API, autenticación, puertos y acceso a datos); controles perimetrales y sus limitaciones.

3.3. Elementos de síntesis obligatorios

Al finalizar el desarrollo temático, incorporar:

- Una **tabla comparativa** con cinco amenazas: hardware, código, scripts incrustados, diseño y arquitectura. Para cada una, incluir un ejemplo, una posible consecuencia y una medida de mitigación.
- Un **esquema o tabla** que relacione al menos cuatro fases del SDLC con prácticas de seguridad y resiliencia pertinentes.
- Una **conclusión de dos o tres párrafos** que explique cómo el enfoque preventivo reduce la exposición a vulnerabilidades y fortalece la resiliencia, sin afirmar resultados cuantitativos no demostrados.

4. Entregables

1. **Un documento final en PDF**, legible y organizado.
2. **Estructura mínima del documento del estudiante:** portada; índice; introducción; desarrollo descriptivo de los apartados 1.1, 1.2 y 1.3 con todos sus subtemas; tabla de amenazas; esquema de seguridad en el SDLC; conclusiones; y referencias bibliográficas.
3. **Formato:** páginas A4, márgenes de 2,5 cm aproximadamente, tipografía legible de 11 o 12 puntos, interlineado de 1,15 a 1,5 y numeración de páginas. Las figuras y tablas deberán estar identificadas y citar la fuente cuando corresponda.
4. **Nombre del archivo:** `Apellido_Nombre_U1_ResumenSeguridad.pdf`. Subir el PDF en el espacio habilitado en Moodle, dentro del plazo indicado por el docente.

Observación de integridad académica. El documento debe demostrar síntesis y redacción propias. Las citas textuales, si resultan indispensables, serán breves y estarán identificadas. La reproducción de información sin atribución no será considerada un resumen original.

5. Rúbrica de evaluación

La actividad se calificará sobre **20 puntos**. La puntuación de cada criterio se asignará de acuerdo con las evidencias presentadas y su calidad; los elementos no incluidos recibirán cero en el criterio correspondiente.

Criterio	Evidencias para la calificación máxima	Puntaje
Cobertura y organización temática	Desarrolla los 15 subtemas de 1.1, 1.2 y 1.3 sin omisiones relevantes; presenta secuencia lógica y síntesis comprensible.	6
Rigor conceptual y precisión técnica	Emplea conceptos correctos, diferencia amenazas de vulnerabilidades y riesgos, y explica adecuadamente las propiedades de seguridad.	4
Ejemplificación y comparación	Incluye ejemplos pertinentes y completa la tabla comparativa de cinco niveles con consecuencias y mitigaciones coherentes.	3
Integración en el SDLC	Relaciona al menos cuatro fases del desarrollo con prácticas concretas de seguridad y resiliencia; formula conclusiones consistentes.	3
Fuentes, citas y referencias	Presenta al menos seis fuentes válidas, cumple la diversidad indicada y mantiene un estilo APA 7 o IEEE uniforme.	2
Redacción y presentación	Entrega un PDF ordenado, legible, con ortografía adecuada, portada, apartados, tablas y formato solicitados.	2
	TOTAL	**20**

Referencia orientativa de desempeño por criterio: excelente (90–100 % del puntaje); satisfactorio (70–89 %); básico (50–69 %); insuficiente (0–49 %). La valoración considera la completitud, la exactitud y la calidad de la evidencia, no solo la cantidad de texto.

6. Anexos

Anexo A. Modelo de tabla comparativa

El siguiente formato es **una plantilla orientativa** que cada estudiante deberá completar con ejemplos propios y fundamentados:

Nivel	Amenaza o ejemplo	Consecuencia	Medida de mitigación
Hardware			
Código			
Scripts incrustados			
Diseño			
Arquitectura			

Anexo B. Modelo de integración con el SDLC

Incluir un cuadro similar para evidenciar la articulación entre etapa, actividad preventiva y objetivo de seguridad:

Fase del SDLC	Práctica de seguridad	Propósito o riesgo mitigado
Requisitos		
Diseño		
Implementación		
Pruebas o despliegue		

Anexo C. Orientación para las citas

- **IEEE:** citas numéricas según aparición. Ejemplo: "Las prácticas seguras deben integrarse durante el desarrollo" [1]. La referencia bibliográfica se presenta al final con su número.
- **APA 7:** citas de autor y año. Ejemplo: "La gestión del riesgo requiere valoración sistemática" (Joint Task Force Transformation Initiative, 2012). La lista final se ordena alfabéticamente según las normas APA.
- **No mezclar estilos:** escoger una sola convención y aplicarla en el texto, tablas, figuras y referencias. Las cinco fuentes recogidas al final de esta guía son *referencias de apoyo*, no sustituyen la selección y lectura de fuentes por parte del estudiante.

Anexo D. Lista de verificación antes de entregar

☐ Están presentes los 15 subtemas y los tres bloques 1.1, 1.2 y 1.3.
☐ Cada concepto está explicado con palabras propias y con ejemplos pertinentes.
☐ Se incluyen la tabla comparativa, el cuadro del SDLC y las conclusiones.
☐ Todas las afirmaciones tomadas de fuentes externas están citadas.
☐ La bibliografía contiene al menos seis fuentes y respeta APA 7 o IEEE.
☐ El archivo PDF se abre correctamente, es legible y tiene el nombre requerido.

Referencias de apoyo

[1] M. Souppaya, K. Scarfone y D. Dodson, *Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities*, NIST SP 800-218, 2022. doi: 10.6028/NIST.SP.800-218.

[2] Joint Task Force Transformation Initiative, *Guide for Conducting Risk Assessments*, NIST SP 800-30, Rev. 1, 2012. doi: 10.6028/NIST.SP.800-30r1.

[3] OWASP Foundation, *OWASP Top 10:2025*, 2025. [En línea]. Disponible en: `https://top10.owasp.org/`.

[4] MITRE, *2025 CWE Top 25 Most Dangerous Software Weaknesses*, 2025. [En línea]. Disponible en: `https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25`.

[5] R. Ross, M. Winstead y M. McEvilley, *Engineering Trustworthy Secure Systems*, NIST SP 800-160, vol. 1, Rev. 1, 2022. doi: 10.6028/NIST.SP.800-160v1r1.